



Declaração de aplicabilidade (SoA)

Versão: 25/03/2026

Índice de revisões

Rev.	Data	Revisões realizadas
0	30/06/2023	- Emissão inicial. Nível de maturidade geral: 2,1
1	05/01/2024	- Atualização sobre aplicabilidade e estado dos controles; A análise maturidade dos controles e as oportunidades de melhoria serão descritas na Análise Crítica Independente de Segurança da informação; Controles que deixaram de ser aplicáveis após a revisão do escopo: 5.08, 7.09, 8.04, 8.30, 8.33 e 8.34
2	23/01/2025	- Reaprovação do documento.
3	25/03/2026	- A.5.02 - Retirado o Voalle da seção 'situação atual'; A.5.06 - Alterado o responsável pelo controle de administrador de redes para SOC; A.5.07 – Retirado a opção 'Planilha com IPs' da base de conhecimento. Incluído 'Informações alimentadas ao sistema de inteligência de ameaças Open CTI' e 'Casos tratados e documentados no sistema The Hive'; A.5.17 - Retirado o Voalle da seção 'situação atual' e incluído Bitrix24. A.5.24 – Retirado o Walguard da lista de sistemas, inserido o Wazuh como SIEM utilizado atualmente; A.5.27 – Retirado o sistema de registro de conhecimento de Voalle, inserido o sistema Bitrix24 como CRM; A.8.07 – Alterado o responsável pelo controle de Analista de TI para SOC; A.8.08 - Incluído Osiris como sistema de base de conhecimento; A.8.11 - Retirado sistema Voalle da seção 'situação atual'; A.8.15 - Incluído Analista SOC em responsável pelo controle; A.8.16 - Retirado o Elastic Flow e incluído o Wazuh em sistemas de monitoramento; Incluído e-mail do soc como forma de notificações por com portamentos anômalos; Incluído SOC em responsável pelo controle; Realizado atualização da seção G – lista de controle por responsáveis.

As informações contidas deste documento são de propriedade da Interjato Serviços de Telecomunicações Ltda e Interjato Telecom Ltda., sendo proibida sua reprodução, divulgação e utilização sem autorização expressa da organização.

Sumário

	página
A - Identificação da organização	04
B - Objetivo	04
C - Metodologia	04
D - Abrangência	04
E - Controles aplicáveis	05
A05 - Controles organizacionais	05
A06 - Controles de pessoas	19
A07 - Controles físicos	23
A08 - Controles tecnológicos	28
F - Controles não-aplicáveis	37
G - Lista de controles por responsável	40

A. Identificação da organização

Razão Social: Interjato Serviços de Telecomunicações Ltda e Interjato Telecom Ltda.

CNPJ: 10.934.803/0001--77 e 07.387.503/0001-00

CNAE Atividade Principal: 61.10-8-03 - Serviços de comunicação multimídia - SCM

B. Objetivo

Apresentar a Declaração de Aplicabilidade (SoA), contendo os controles necessários e a justificativa para inclusões de controles sejam eles implementados ou não, bem como a justificativa para a exclusão dos controles do Anexo A da NBR ISO/IEC 27001:2022.

C. Metodologia

Esta Declaração de Aplicabilidade foi elaborada com base nas nos riscos identificados e informações disponíveis em documentos e práticas em uso na organização analisadas na data de revisão deste documento.

As referências aos riscos nesta SoA são as mesmas utilizadas nas Matrizes de Risco

As ações que sejam necessárias para aperfeiçoamento dos controles serão definidas na Análise Crítica Independente da Segurança da Informação.

D. Abrangência

Esse diagnóstico considerou as seguintes unidades/locais:

(L01) Sede Rua Mirabeau da Cunha Melo, 1943, Candelaria, Natal - RN, 59064-490

E. Controles aplicáveis

A05 - Controles organizacionais

A.5.01 Políticas de segurança da informação

A política de segurança da informação e as políticas específicas por tema devem ser definidas, aprovadas pela direção, publicadas, comunicadas e reconhecidas pelo pessoal pertinente e pelas partes interessadas pertinentes, e analisadas criticamente em intervalos planejados e quando ocorrerem mudanças significativas.

Situação atual:

- Justificativa para inclusão: Políticas para Segurança da Informação (geral e específicas) são necessárias para orientar a aplicação de vários controles de Segurança da Informação.
- Os temas específicos e os respectivos documentos com políticas estão descritos no item 10.1 do Manual do SGSI. Atualmente existem 21 temas abordados por políticas, que estão presentes em diferentes documentos internos.
- O PG-01 (Controle da informação documentada) prevê que todos os documentos normativos sejam revisados anualmente.

Riscos: 1.1 a 1.9; 1.25 a 1.27; 2.3 a 2.5; 3.6 e 3.7; 5.3; 5.12 a 5.14; 5.31, 5.32; 7.1 a 7.16

Responsável pelo controle: Direção

Forma de monitoramento: Alcance dos objetivos de segurança da informação associados às diretrizes das políticas e constatações das Auditorias internas

A.5.02 Papéis e responsabilidades pela segurança da informação

Papéis e responsabilidades pela segurança da informação devem ser definidos e alocados de acordo com as necessidades da organização.

Situação atual:

- Justificativa para inclusão: A definição de papéis e responsabilidades claros para a segurança da informação é fundamental para garantir que as práticas de segurança sejam implementadas de forma eficaz na organização.
- As responsabilidades e autoridades de cada função associadas a escopo do SGSI estão descritas nos documentos normativos do SGSI.

Riscos: 3.1 a 3.3; 7.3 a 7.5

Responsável pelo controle: Comitê de Segurança da Informação

Forma de monitoramento: Auditorias internas do SGSI

A.5.03 Segregação de funções

Funções conflitantes e áreas de responsabilidade devem ser segregadas.

Situação atual:

- Justificativa para inclusão: o controle é necessário porque ajuda a prevenir conflitos de interesse, erros acidentais e fraudes.
- Os processos da segurança da informação foram estruturados e as funções são definidas e segregadas conforme as responsabilidades e autoridades associadas e definidas nos documentos normativos do SGSI.

Riscos: 3.1 a 3.3; 6.1; 7.3 a 7.5, 7.9 a 7.11

Responsável pelo controle: Direção

Forma de monitoramento: Análise crítica independente da segurança da informação

A.5.04 Responsabilidades da direção

A direção deve requerer que todo o pessoal aplique a segurança da informação de acordo com a política da segurança da informação estabelecida, com as políticas específicas por tema e com os procedimentos da organização.

Situação atual:

- Justificativa para inclusão: A eficácia do SGSI ficará comprometida caso a liderança não exerça sua autoridade organizacional para aumentar o engajamento da equipe no cumprimento da política da segurança da informação, das políticas específicas por tema e dos procedimentos da organização.
- A Direção atua no sentido de engajar as pessoas para o cumprimento política da segurança da informação.

Riscos: 1.1 a 1.9; 1.25 a 1.27; 2.3 a 2.5; 3.6 e 3.7; 5.3; 5.12 a 5.14; 5.31, 5.32; 7.1 a 7.16

Responsável pelo controle: Direção

Forma de monitoramento: Auditorias internas do SGSI

A.5.05 Contato com autoridades

A organização deve estabelecer e manter contato com as autoridades relevantes.

Situação atual:

- Justificativa para inclusão: O contato com autoridades está previsto em requisitos legais, principalmente no sentido de fornecimento de informações solicitadas pelos órgãos fiscalizadores (ver análise de partes interessadas). O descumprimento das solicitações recebidas poderá acarretar sanções legais.
- O contato com autoridades, quando necessário, é realizado pela Diretoria ou DPO, conforme definido no PG-03 (Comunicação).

Riscos: Riscos do Grupo de ativos 6 (Dados pessoais)

Responsável pelo controle: DPO

Forma de monitoramento: Reuniões periódicas do Comitê de Segurança da Informação

A.5.06 Contato com grupos de interesse especial

A organização deve estabelecer e manter contato com grupos de interesse especial ou com outros fóruns de especialistas em segurança e associações profissionais.

Situação atual:

- Justificativa para inclusão: o contato com grupos de interesse facilita a obtenção de informações atualizadas, a fim de prover proteção adequada contra os riscos aos quais a organização está exposta.
- Foi estabelecido um grupo de trabalho no Bitrix "Programa de Conscientização em Segurança da Informação", que lista os grupos de interesse especial, tornando disponíveis para os participantes.

Riscos: 5.1, 5.2; 5.4 a 5.6; 5.19 a 5.22; 7.15 a 7.17

Responsável pelo controle: SOC

Forma de monitoramento: Reuniões periódicas do Comitê de Segurança da Informação

A.5.07 Inteligência de ameaças

As informações relacionadas a ameaças à segurança da informação devem ser coletadas e analisadas para produzir inteligência de ameaças.

Situação atual:

- Justificativa para inclusão: o conhecimento baseado em evidências, incluindo contexto, mecanismos, indicadores, implicações e conselhos acionáveis, sobre uma ameaça ou risco existente ou emergente para ativos de informação é útil para orientar decisões sobre a resposta a essa ameaça ou risco.
- As bases de conhecimento utilizadas para a inteligência de ameaças, incluem:
 - Informações alimentadas ao sistema de inteligência de ameaças Open CTI;
 - Informações estatísticas sobre tipos de incidentes abordados na empresa;
 - Informações obtidas dos grupos de interesse;
 - Casos tratados e documentados no sistema The Hive.

Riscos: 5.1, 5.2; 5.4 a 5.6; 5.19 a 5.22; 7.15 a 7.17

Responsável pelo controle: SOC

Forma de monitoramento: Status de atualização no grupo de trabalho específico no Bitrix

A.5.09 Inventário de informações e outros ativos associados

Um inventário de informações e outros ativos associados, incluindo proprietários, deve ser desenvolvido e mantido.

Situação atual:

- Justificativa para inclusão: Não há como controlar os riscos à segurança da informação sem conhecer os ativos de informação envolvidos.
- O PG-17 (Gestão de Ativos de Informação) aborda o inventário de informações, com regras sobre codificação, nível de ativos, atributos do cadastro de ativos e responsabilidades envolvidas.
- O inventário sobre os ativos de rede está no Netbox, o inventário de informações em banco de dados está definido no registro R-14 e demais ativos estão inventariados no GLPI

Riscos: Riscos associados a todos os ativos de informação

Responsável pelo controle: Analista de TI

Forma de monitoramento: Atualização semestral do inventário

A.5.10 Uso aceitável de informações e outros ativos associados

Regras para o uso aceitável e procedimentos para o manuseio de informações e outros ativos associados devem ser identificados, documentados e implementados.

Situação atual:

- Justificativa para inclusão: regras e procedimentos estabelecem diretrizes claras sobre como as informações devem ser tratadas e protegidas, e ajudam a minimizar o risco de violações de segurança.
- A IT-03 traz as regras para classificação, rotulagem e manuseio da informação.

- A IT-04 (Uso Aceitável de Ativos) traz regras do uso aceitável de ativos, envolvendo os equipamentos computacionais da empresa ou de propriedade dos usuários, recursos em nuvem, mídia de armazenamento, equipamentos de impressão e reprografia.
- A IT-06 (Internet e mídias sociais) aborda o uso aceitável do acesso à internet.
- A IT-07 (e-mail) traz as diretrizes para utilização adequada dos serviços de e-mail.

Riscos: 1.1 a 1.9; 2.3 a 2.5; 2.13, 2.14; 3.4 a 3.10; 5.3, 5.22; riscos do grupo de ativos 6; 7.12 a 7.1

Responsável pelo controle: Comitê de Segurança da Informação

Forma de monitoramento: Reuniões periódicas do Comitê de Segurança da Informação

A.5.11 Devolução de ativos

O pessoal e outras partes interessadas, conforme apropriado, devem devolver todos os ativos da organização em sua posse após a mudança ou o encerramento da contratação ou acordo.

Situação atual:

- Justificativa para inclusão: a falta de devolução dos ativos em poder de funcionários ou terceiros, após a mudança ou o encerramento da contratação ou acordo, traz riscos relacionados à confidencialidade de informações e perdas financeiras associadas aos ativos.
- O RH controla a devolução aos colaboradores através de cobrança baseada nos Termos de Responsabilidade - equipamento.
- O PG-14 (Relacionamento com fornecedores) prevê que os instrumentos contratuais incluam requisitos relacionados a:
 - Provisão de um método de destruição segura das informações da organização armazenadas pelo fornecedor assim que não for mais necessária;
 - Devolução de ativos.

Riscos: 2.3 a 2.5

Responsável pelo controle: Analista de TI

Forma de monitoramento: Atualização semestral do inventário

A.5.12 Classificação das informações

As informações devem ser classificadas de acordo com as necessidades de segurança da informação da organização, com base na confidencialidade, integridade, disponibilidade e requisitos das partes interessadas relevantes.

Situação atual:

- Justificativa para inclusão: a classificação das informações ajuda a direcionar as medidas de proteção adequadas com base na sensibilidade das informações.
- A IT-03 define 3 níveis de classificação (Pública, de Uso Interno e Confidencial). Para cada um dos níveis de classificação a Tabela do Anexo 1 define as formas de lidar com a informação. Foram considerados requisitos de partes interessadas, tais como o impacto nos negócios, a proteção de dados pessoais e os direitos autorais.
- O registro da classificação das informações está no Quadro de Controle de Registros e dados pessoais.

Riscos: 3.1 a 3.4 e riscos do grupo de ativos 6

Responsável pelo controle: Analista de TI

Forma de monitoramento: Análise crítica independente da segurança da informação

A.5.13 Rotulagem de informações

Um conjunto adequado de procedimentos para rotulagem de informações deve ser desenvolvido e implementado de acordo com o esquema de classificação de informações adotado pela organização.

Situação atual:

- Justificativa para inclusão: A rotulagem de informações classificadas é um requisito importante para o compartilhamento de informações.
- A rotulagem também está definida no quadro de controle de registros (coluna com definições de Acesso).
- IT-03 (Classificação da informação) define as regras para rotulagem da informação.

Riscos: 3.1 a 3.4 e riscos do grupo de ativos 6

Responsável pelo controle: Analista de TI

Forma de monitoramento: Análise crítica independente da segurança da informação

A.5.14 Transferência de informações

Regras, procedimentos ou acordos de transferência de informações devem ser implementados para todos os tipos de recursos de transferência dentro da organização e entre a organização e outras partes.

Situação atual:

- Justificativa para inclusão: Esse controle é necessário para manter a segurança das informações transferidas fora dos limites da organização.
- Exemplo de situações onde há transferência de informações: informações enviadas a autoridades por demandas judiciais, realização de trabalho remoto pela força de trabalho, informações a fornecedores para que estes realizem serviços para a empresa e informações a fornecedores para que estes realizem serviços em nome da empresa.
- As regras estabelecidas para lidar com transferências de informações estão descritas no PG-03 (Comunicação).
- A tabela 1 da IT-03 (Classificação, rotulagem e manuseio de informação) descreve uso aceitável de transmissão, conforme classificação da informação.

Riscos: 3.1 a 3.4 e riscos do grupo de ativos 6

Responsável pelo controle: Emissores de comunicações (conforme quadro no PG-03)

Forma de monitoramento: Análise crítica independente da segurança da informação

A.5.15 Controle de acesso

Regras para controlar o acesso físico e lógico às informações e a outros ativos associados devem ser estabelecidas e implementadas com base nos requisitos de segurança da informação e de negócios.

Situação atual:

- Justificativa: Sem regras definidas e aplicadas para o controle de acesso, pessoas não autorizadas podem ter acesso a ativos de informação, com riscos à confidencialidade, integridade e disponibilidade de informações.
- A empresa utiliza identificação biométrica para acesso à Sala do Data Center (facial e digital) e outros ambientes da empresa (digital), com privilégios parametrizados na base Hikvisio. O acesso geral é controlado pela recepção.
- A IT-05 (Gestão de identidade e acesso aos ativos) traz as diretrizes para acesso a ativos e sistemas de informação, senhas de acesso e autorização de acesso (privilégios de acesso).
- A inclusão ou exclusão de acessos nos grupos é feita através do Active Directory.

Riscos: 3.1 a 3.3; 4.3 a 4.5, 4.10 a 4.12; 5.3, 5.12 a 5.14, 5.31, 5.32; 6.1; 7.3

Responsável pelo controle: Gerente de NOC/Suporte

Forma de monitoramento: Análise crítica independente da segurança da informação

A.5.16 Gestão de identidade

O ciclo de vida completo das identidades deve ser gerenciado.

Situação atual:

- Justificativa para inclusão: A identificação única é necessária para permitir a cessão adequada de direitos de acesso às informações e outros ativos associados.
- A IT-05 (Gestão de Identidade e Acesso aos ativos) trata especificamente das diretrizes para este tema.
- Para alguns acessos físicos (ver A.5.15), a identificação biométrica é gerenciada pelo RH.
- A inclusão ou exclusão de usuários é feita através do Active Directory.

Riscos: 3.1 a 3.3; 4.3 a 4.5, 4.10 a 4.12; 5.3, 5.12 a 5.14, 5.31, 5.32; 6.1; 7.3

Responsável pelo controle: Analista de TI

Forma de monitoramento: Análise crítica independente da segurança da informação

A.5.17 Informações de autenticação

A alocação e a gestão de informações de autenticação devem ser controladas por uma gestão de processo, incluindo aconselhar o pessoal sobre o manuseio adequado de informações de autenticação.

Situação atual:

- Justificativa para inclusão: a autenticação é necessária para determinar se a pessoa que está tentando acessar um ativo de informação está realmente autorizada e cadastrada para tanto, de forma a evitar riscos à segurança da informação.
- Algumas regras para senhas estão descritas na IT-05 (Gestão de Identidade e Acesso aos ativos), que incluem os requisitos para formulação e o prazo de validade da senha.
- Alguns serviços como o e-mail e o Bitrix24 não estão sujeitos à autenticação pelo Active Directory.

Riscos: 3.1 a 3.3; 4.3 a 4.5, 4.10 a 4.12; 5.3, 5.12 a 5.14, 5.31, 5.32; 6.1; 7.3

Responsável pelo controle: Analista de TI

Forma de monitoramento: Análise crítica independente da segurança da informação

A.5.18 Direitos de acesso

Os direitos de acesso às informações e a outros ativos associados devem ser provisionados, analisados criticamente, modificados e removidos de acordo com a política de tema específico e com as regras da organização para o controle de acesso.

Situação atual:

- Justificativa para inclusão: o gerenciamento dos direitos de acesso ajuda a garantir que apenas usuários autorizados tenham acesso aos dados e sistemas da organização.

Riscos: 3.1 a 3.3; 4.3 a 4.5, 4.10 a 4.12; 5.3, 5.12 a 5.14, 5.31, 5.32; 6.1; 7.3

Responsável pelo controle: Gerente de NOC/Suporte

Forma de monitoramento: Análise crítica independente da segurança da informação

A.5.19 Segurança da informação nas relações com fornecedores

Processos e procedimentos devem ser definidos e implementados para gerenciar a segurança da informação e os riscos associados com o uso dos produtos ou serviços dos fornecedores.

Situação atual:

- Justificativa para inclusão: É necessário proteger os dados confidenciais compartilhados com fornecedores, proteger a propriedade intelectual de ativos de informação da organização que eventualmente sejam utilizados pelos fornecedores, cumprir requisitos legais como a LGPD. Além disso, a falta de segurança adequada nos sistemas e dados compartilhados com fornecedores pode levar a interrupções no fornecimento de produtos ou serviços, o que pode afetar a capacidade da organização de atender às demandas do mercado.
- O PG-14 (Relacionamento com fornecedores) classifica os fornecedores em 3 tipos e determina:
 - a) requisitos a serem cumpridos pelos fornecedores;
 - b) controles a serem aplicados, conforme o tipo de fornecedor;
 - c) Termo de responsabilidade para contratadas, que inclui requisitos de segurança da informação.

Riscos: 1.12 a 1.14, 1.17 a 1.19, 2.15 a 2.18; 5.23 a 5.28; 6.14, 6.15

Responsável pelo controle: Comitê de Segurança da Informação

Forma de monitoramento: Reuniões periódicas do Comitê de Segurança da Informação

A.5.20 Abordagem da segurança da informação nos contratos de fornecedores

Requisitos relevantes de segurança da informação devem ser estabelecidos e acordados com cada fornecedor, com base no tipo de relacionamento com o fornecedor.

Situação atual:

- Justificativa para inclusão: A existência de contratos contribui para que haja um claro entendimento sobre as obrigações de ambas as partes, além de trazer maior segurança jurídica para lidar com questões relacionadas à Segurança da Informação.
- O PG-14 (Relacionamento com fornecedores) determina requisitos a serem cumpridos pelos fornecedores, a serem incorporados nos instrumentos contratuais.

Riscos: 1.12 a 1.14, 1.17 a 1.19, 2.15 a 2.18; 5.23 a 5.28; 6.14, 6.15

Responsável pelo controle: Assessoria Jurídica

Forma de monitoramento: Reuniões periódicas do Comitê de Segurança da Informação

A.5.21 Gestão da segurança da informação na cadeia de fornecimento de TIC

Processos e procedimentos devem ser definidos e implementados para gerenciar os riscos da segurança da informação associados à cadeia de fornecimento de produtos e serviços de TIC.

Situação atual:

- Justificativa para inclusão: Fornecedores de TIC possuem maior impacto no desempenho de segurança da informação e, por consequência, a cadeia de fornecimento de TIC está associada a riscos mais relevantes.
- O PG-14 (Relacionamento com fornecedores) classifica os fornecedores em 3 tipos e determina:
 - a) requisitos a serem cumpridos pelos fornecedores;
 - b) controles a serem aplicados, conforme o tipo de fornecedor;
 - c) Termo de responsabilidade para contratadas, que inclui requisitos de segurança da informação.

Riscos: 1.12 a 1.14, 1.17 a 1.19, 2.15 a 2.18; 5.23 a 5.28; 6.14, 6.15

Responsável pelo controle: Analista de TI

Forma de monitoramento: Reuniões periódicas do Comitê de Segurança da Informação

A.5.22 Monitoramento, análise crítica e gestão de mudanças dos serviços de fornecedores

A organização deve monitorar, analisar criticamente, avaliar e gerenciar regularmente a mudança nas práticas da segurança da informação dos fornecedores e na prestação de serviços.

Situação atual:

- Justificativa para inclusão: Mudanças nos serviços dos fornecedores podem alterar os níveis de risco previamente identificados e controlados.
- A sistemática de gestão de mudanças está definida no PG-08, com previsão para gestão de mudanças dos serviços de fornecedores, conforme o Anexo 2 do PG-08.

Riscos: 1.12 a 1.14, 1.17 a 1.19, 2.15 a 2.18; 5.23 a 5.28; 6.14, 6.15

Responsável pelo controle: Gerente de NOC/Suporte

Forma de monitoramento: Auditorias internas do SGSI

A.5.23 Segurança da informação para uso de serviços em nuvem

Os processos de aquisição, uso, gestão e saída de serviços em nuvem devem ser estabelecidos de acordo com os requisitos da segurança da informação da organização.

Situação atual:

- Justificativa para inclusão: Os dados armazenados e processados em nuvem estão sujeitos a uma variedade de ameaças de segurança cibernética. Além disso, a natureza distribuída da nuvem torna mais difícil o controle sobre a segurança dos seus dados, uma vez que a responsabilidade pela segurança dos dados é compartilhada com o provedor de serviços em nuvem.

- O item 4.4 da IT-04 (Uso aceitável de Ativos) proíbe o uso de qualquer outra solução de armazenamento na nuvem que não seja a oficialmente adotada pela empresa e homologada pelo NOC.

Riscos: 1.10, 1.11, 1.17 a 1.19, 1.21 a 1.23; 3.8 a 3.10; 6.9, 6.14, 6.15

Responsável pelo controle: Diretoria Técnica

Forma de monitoramento: Auditorias internas do SGSI

A.5.24 Planejamento e preparação da gestão de incidentes da segurança da informação

A organização deve planejar e se preparar para gerenciar incidentes da segurança da informação, definindo, estabelecendo e comunicando processos, papéis e responsabilidades de gestão de incidentes da segurança da informação.

Situação atual:

- Justificativa para inclusão: À medida que vários e numerosos incidentes ocorrem e estão aumentando, é necessário uma estrutura adequada para lidar eficientemente com incidentes e preservar a confidencialidade, a integridade e a disponibilidade das informações.
- O PG-15 (Gestão de incidentes da segurança da informação) traz a sistemática para planejamento e preparação para resposta a incidentes de informação.
Além dos sistemas para detecção de eventos que podem constituir incidentes (Zabbix, Sistema correlação de logs e SIEM Wazuh e Kaspersky), qualquer colaborador pode comunicar eventos.
Eventos de natureza técnica são direcionados ao SOC e aqueles de natureza não-técnica são recebidos e tratados pelo CSI.
- As principais práticas utilizadas para detecção de incidentes são: terceiros (Ex.: Abuse, Virustotal, NIST), comunicação pessoal, Zabbix, Correlação de logs e SIEM Wazuh, e Kaspersky.
- Foi disponibilizado formulário eletrônico, com acesso através de QR Code disponível à equipe para que os eventos de segurança da informação sejam notificados.

Riscos: Todos os riscos relacionados na matriz de riscos

Responsável pelo controle: SOC

Forma de monitoramento: Atividades do SOC

A.5.25 Avaliação e decisão sobre eventos da segurança da informação

A organização deve avaliar os eventos da segurança da informação e decidir se categoriza como incidentes da segurança da informação.

Situação atual:

- Justificativa para inclusão: Uma avaliação correta sobre um evento, decidindo adequadamente se há necessidade de tratá-lo como incidente de segurança da informação ajuda a direcionar os esforços da organização (evitando gasto desnecessário de recursos em investigações e soluções de problemas que não são relevantes ou críticos para a segurança da informação) e, por outro lado, se um evento for classificado erroneamente, isso pode levar a uma falta de ações necessárias, o que pode colocar em risco os ativos de informação da organização.
- A sistemática para avaliar e decidir sobre eventos de segurança da informação está definida no PG-15 (Gestão de incidentes da segurança da informação).

Riscos: Todos os riscos relacionados na matriz de riscos

Responsável pelo controle: SOC

Forma de monitoramento: Análise crítica independente da segurança da informação

A.5.26 Resposta a incidentes de segurança da informação Os incidentes da segurança da informação devem ser respondidos de acordo com os procedimentos documentados.

Situação atual:

- Justificativa para inclusão: a resposta a um incidente é necessário para conter, erradicar e recuperar um incidente, de forma a parar ou minimizar os efeitos ou danos do ataque, mantendo a continuidade da missão operacional e prevenir que incidentes semelhantes ocorram novamente.
- O PG-15 (Gestão de incidentes da segurança da informação) traz a sistemática para análise, contenção, erradicação e recuperação de incidente.

Riscos: Todos os riscos relacionados na matriz de riscos

Responsável pelo controle: SOC

Forma de monitoramento: Análise crítica independente da segurança da informação

A.5.27 Aprendizado com incidentes de segurança da informação O conhecimento adquirido com incidentes de segurança da informação deve ser usado para fortalecer e melhorar os controles da segurança da informação.

Situação atual:

- Justificativa para inclusão: Sem utilizar o conhecimento adquirido no tratamento de incidentes de segurança da informação, há o risco de ter esforços aumentados no tratamento de incidentes que já aconteceram. Por outro lado, o aprendizado aumentará a capacidade de lidar mais efetivamente com incidentes de segurança no futuro, minimizando impactos, além de fortalecer a cultura de segurança da organização.
- Cabe ao SOC ou o CSI, conforme a natureza dos incidentes, elaborar relatório pós-tratamento, utilizando solicitações no sistema Bitrix24. Em suas reuniões rotineiras o CSI discute as lições aprendidas sobre a resposta a incidentes de SI no período e sobre como incorporá-las no dia-a-dia da organização, o que pode incluir: revisão nas matrizes de risco, revisão técnica do conteúdo de políticas de SI associadas ao tratamento de incidentes, quando necessário e disseminação, como apropriado, das lições aprendidas com a força de trabalho.

Riscos: Todos os riscos relacionados na matriz de riscos

Responsável pelo controle: SOC

Forma de monitoramento: KPI específico associado ao tema

A.5.28 Coleta de evidências A organização deve estabelecer e implementar procedimentos para identificação, coleta, aquisição e preservação de evidências relacionadas a eventos da segurança da informação.

Situação atual:

- Justificativa para inclusão: O controle de evidências é necessário para assegurar uma gestão consistente e eficaz das evidências relacionadas a incidentes de segurança da informação para fins disciplinares e legais.

- Os cuidados sobre a preservação de evidências estão previstos no item 5.3 e Anexo 3 do PG-15 (Tratamento de incidentes de Segurança da Informação).

Riscos: Todos os riscos relacionados na matriz de riscos

Responsável pelo controle: SOC

Forma de monitoramento: Reuniões periódicas do Comitê de Segurança da Informação

A.5.29 Segurança da informação durante a interrupção

A organização deve planejar como manter a segurança da informação em um nível apropriado durante a interrupção.

Situação atual:

- Justificativa para inclusão: Se não for adequadamente gerenciada, uma interrupção significativa nas operações da organização (que pode ser causada por um incidente de segurança da informação, como um ataque cibernético, uma falha do sistema ou um desastre natural) leva a prejuízos relevantes para a organização e seus clientes.
- Há planos de continuidade que pode ser associados a interrupções: PL-01 (incêndio na sede), PL-02 (Falha no fornecimento de energia), PL-03 (Restrições sanitárias), PL-04 (Indisponibilidade das operadoras de internet), PL-05 (Indisponibilidade do Zabbix).

Riscos: 2.14; 3.11, 3.12; 4.1 a 4.9, 4.15; 5.2, 5.4 a 5.6, 5.18

Responsável pelo controle: Comitê de Segurança da Informação

Forma de monitoramento: Testes nos Planos de Continuidade e acompanhamento de situações r

A.5.30 Prontidão de TIC para continuidade de negócios

A prontidão de TIC deve ser planejada, implementada, mantida e testada com base nos objetivos de continuidade de negócios e nos requisitos de continuidade da TIC.

Situação atual:

- Justificativa para inclusão: a continuidade de negócios deve ser mantida para minimizar os impactos causados por uma interrupção.
- Há planos de continuidade que pode ser associados a interrupções: PL-01 (incêndio na sede), PL-02 (Falha no fornecimento de energia), PL-03 (Restrições sanitárias), PL-04 (Indisponibilidade das operadoras de internet), PL-05 (Indisponibilidade do Zabbix).

Riscos: 2.14; 3.11, 3.12; 4.1 a 4.9, 4.15; 5.2, 5.4 a 5.6, 5.18

Responsável pelo controle: Comitê de Segurança da Informação

Forma de monitoramento: Testes nos Planos de Continuidade e acompanhamento de situações r

A.5.31 Requisitos legais, estatutários, regulamentares e contratuais

Os requisitos legais, estatutários, regulamentares e contratuais pertinentes à segurança da informação e à abordagem da organização para atender a esses requisitos devem ser identificados, documentados e atualizados.

Situação atual:

- Justificativa para inclusão: a ausência de identificação e aplicação de requisitos legais, estatutários, regulamentares e contratuais pode levar a sanções legais, prejuízos à imagem da empresa e, em casos extremos, à descontinuidade do negócio.
- Em maio de 2023 foi realizado um levantamento inicial de legislação, atualizado em dezembro de 2023.

Riscos: Riscos do grupo de ativos 6

Responsável pelo controle: Comitê de Segurança da Informação

Forma de monitoramento: Auditorias internas Do SGSI

A.5.32 Direitos de propriedade intelectual

A organização deve implementar procedimentos adequados para proteger os direitos de propriedade intelectual

Situação atual:

- Justificativa para inclusão: A proteção de direitos de propriedade intelectual está prevista em leis (Leis Nº 9.609 e Nº 9.610, ambas de 19/02/1998).
- O item 8.1 da IT-03 (Classificação das informações) traz orientações regras associadas a informações com proteção de direitos autorais.

Riscos: 1.3 a 1.9

Responsável pelo controle: Comitê de Segurança da Informação

Forma de monitoramento: Reuniões periódicas do Comitê de Segurança da Informação

A.5.33 Proteção de registros

Os registros devem ser protegidos contra perdas, destruição, falsificação, acesso não autorizado e liberação não autorizada.

Situação atual:

- Justificativa para inclusão: A proteção de registros é parte essencial da segurança da informação, uma vez que os registros materializam as informações usadas e produzidas pela organização. Esse controle envolve as três dimensões da SI: confidencialidade, integridade e disponibilidade.
- Conforme descreve o item 6.4 do PG-01 (Informação documentada) "As atividades para garantir a proteção da confidencialidade, integridade e disponibilidade das informações são tratadas pelos controles estabelecidos no âmbito do SGSI".

Riscos: 3.1 a 3.10 e riscos do grupo de ativos 6

Responsável pelo controle: Coordenadores ou Gerentes

Forma de monitoramento: Auditorias internas do SGSI

A.5.34 Privacidade e proteção de DP

A organização deve identificar e atender aos requisitos relativos à preservação da privacidade e à proteção de DP, de acordo com as leis e os regulamentos aplicáveis e requisitos contratuais.

Situação atual:

- Justificativa para inclusão: a preservação da privacidade e a proteção de DP são exigidas pela Lei Nº 13.790, de 14/08/2018 (LGPD) e suas alterações.
- O Gerente do NOC e Suporte Técnico está formalmente designado como Encarregado de Dados Pessoais.

- O Quadro de controle de registros e dados pessoais (modelo em anexo ao PG-01) realiza o mapeamento dos dados pessoais, incluindo: quais são os dados pessoais, se são dados sensíveis, hipótese adotada para coleta de dados, forma de obtenção do dado pessoal, terceiros envolvidos em quaisquer etapas do tratamento e com quais as instituições públicas e/ou privadas o dado pessoal é compartilhado.
- Foi elaborado e aprovado o PG-19 (Proteção de Dados Pessoais), com as principais abordagens específicas relacionadas à LGPD.
- O Procedimento PG-15 (Tratamento de incidentes) traz as diretrizes para analisar quais situações nas quais um incidente de segurança da informação que envolva dados pessoais devem ser comunicadas à ANPD e as orientações sobre como fazê-lo.
- O PG-08 prevê que, entre os riscos a serem considerados na gestão de mudanças, deve ser analisado os potenciais impactos à privacidade de dados pessoais.
- Os funcionários assinam o Contrato de observância à Lei Geral de Proteção de Dados, Confidencialidade e Propriedade Intelectual que reforça, na cláusula 4ª, as obrigações da empresa em relação à LGPD.

Riscos: 3.1 a 3.10 e riscos do grupo de ativos 6

Responsável pelo controle: DPO

Forma de monitoramento: Análise crítica independente da segurança da informação

A.5.35 Análise crítica independente da segurança da informação

A abordagem da organização para gerenciar a segurança da informação e sua implementação, incluindo pessoas, processos e tecnologias, deve ser analisada criticamente, de forma independente, a intervalos planejados ou quando ocorrerem mudanças significativas.

Situação atual:

- Justificativa para inclusão: A análise crítica independente da segurança da informação atuará como mecanismo de monitoramento dos vários controles relacionados à Segurança da Informação.
- A primeira análise crítica independente da segurança da informação será realizada durante a auditoria interna do SGSI.

Riscos: Todos os riscos relacionados na matriz de riscos

Responsável pelo controle: Comitê de Segurança da Informação

Forma de monitoramento: Auditorias internas Do SGSI

A.5.36 Compliance com políticas, regras e normas para segurança da informação

O compliance da política de segurança da informação da organização, políticas, regras e normas de temas específicos deve ser analisado criticamente a intervalos regulares.

Situação atual:

- Justificativa para inclusão: Verificar o cumprimento dos requisitos estabelecidos em normas e regras é essencial para identificar eventuais lacunas e manter a conformidade do SGSI.

Riscos: Principalmente riscos do grupo de ativos 6

Responsável pelo controle: Comitê de Segurança da Informação

Forma de monitoramento: Reuniões periódicas do Comitê de Segurança da Informação

**A.5.37 Documentação dos
procedimentos de
operação**

Os procedimentos de operação dos recursos de tratamento da informação devem ser documentados e disponibilizados para o pessoal que necessite deles.

Situação atual:

- Justificativa para inclusão: A abrangência da necessidade de Segurança da Informação para o escopo requer a documentação de práticas como forma de controle de alguns riscos.
- Além do Manual do SGSI, há diversos documentos normativos internos, abrangendo procedimentos gerenciais, instruções de trabalho e planos de continuidade relacionados ao SGSI. Esses documentos são disponibilizados através da plataforma Bitrix.

Riscos: Todos os riscos relacionados na matriz de riscos

Responsável pelo controle: Gerente de NOC/Suporte

Forma de monitoramento: Auditorias internas do SGSI

A06 - Controles de Pessoas

A.6.01 Seleção

Verificações de antecedentes de todos os candidatos a serem contratados devem ser realizadas antes de ingressarem na organização e de modo contínuo, de acordo com as leis, os regulamentos e a ética aplicáveis, e devem ser proporcionais aos requisitos do negócio, à classificação das informações a serem acessadas e aos riscos percebidos.

Situação atual:

- Justificativa para inclusão: As verificações ajudam a reduzir os riscos associados à contratação de pessoas não confiáveis ou com um histórico de comportamento inadequado do ponto de vista da segurança da informação.
- É realizada consulta dos candidatos com relação aos antecedentes criminais no âmbito estadual e federal, com registro em pdf no dossiê do candidato selecionado.

Riscos: 7.6, 7.7

Responsável pelo controle: Recursos Humanos

Forma de monitoramento: Auditorias internas do SGSI

A.6.02 Termos e condições de contratação

Os contratos trabalhistas devem declarar as responsabilidades do pessoal e da organização para a segurança da informação.

Situação atual:

- Justificativa para inclusão: a formalização dos termos e condições relacionadas à segurança da informação contribui para a transparência nas relações e traz maior segurança jurídica para ambas as partes.
- As cláusulas 11 a 16 do Contrato de Trabalho abordam questões relacionadas à Segurança de Informação, com destaque para a privacidade de dados pessoais.
- Na contratação, os funcionários e estagiários também assinam um Termo de confidencialidade que aborda as informações confidenciais da empresa.

Riscos: 7.6, 7.7

Responsável pelo controle: Recursos Humanos

Forma de monitoramento: Auditorias internas do SGSI

A.6.03 Conscientização, educação e treinamento em segurança da informação

O pessoal da organização e partes interessadas relevantes devem receber treinamento, educação e conscientização em segurança da informação apropriados e atualizações regulares da política de segurança da informação da organização, políticas e procedimentos específicos por tema, pertinentes para as suas funções.

Situação atual:

- Justificativa para inclusão: As práticas associadas a esse controle são essenciais para aumentar o engajamento das pessoas em relação às questões de Segurança da Informação na organização.
- Criado grupo de trabalho no Bitrix24 "Conscientização em Segurança da Informação", com a disponibilização de temas relacionados à Segurança da Informação. O grupo inclui todos os colaboradores.

Riscos: 7.9 a 7.16

Responsável pelo controle: Recursos Humanos

Forma de monitoramento: Auditorias internas do SGSI

A.6.04 Processo disciplinar

Um processo disciplinar deve ser formalizado e comunicado, para tomar ações contra pessoal e outras partes interessadas relevantes que tenham cometido uma violação da política da segurança da informação.

Situação atual:

- Justificativa para inclusão: a definição clara das sanções e respectivo processo disciplinar associado a violações na política e regras de segurança da informação contribuem para as pessoas entendam as consequências de ações indevidas e para dissuadi-las de infringir as normas internas.
- A previsão sobre penalidades está descrita na cláusula 7ª do Contrato de observância à Lei Geral de Proteção de Dados, Confidencialidade e Propriedade Intelectual.
- O PG-12 (Regulamento do Comitê de Segurança da Informação) atribui ao CSI a responsabilidade por analisar casos de violações nas políticas e regras de segurança da informação e a autoridade para definir as sanções associadas.

Riscos: 7.9 a 7.16

Responsável pelo controle: Comitê de Segurança da Informação

Forma de monitoramento: Reuniões periódicas do Comitê de Segurança da Informação

A.6.05 Responsabilidades após encerramento ou mudança da contratação

As responsabilidades e funções de segurança da informação que permaneçam válidas após o encerramento ou a mudança da contratação devem ser definidas, aplicadas e comunicadas ao pessoal e a outras partes interessadas pertinentes.

Situação atual:

- Justificativa para inclusão: com o encerramento da contratação, há o risco que informações sensíveis saiam do controle da empresa. Esse controle é necessário para proteger os interesses da organização, incluindo aqueles previstos em requisitos legais como a LGPD.
- Após o encerramento da contratação, os acessos que são baseados em biometria são removidos (portão e relógio de ponto), uma demanda de bloqueio das credenciais de acesso aos sistemas é feita ao NOC.
- O Contrato de observância à Lei Geral de Proteção de Dados, Confidencialidade e Propriedade Intelectual prevê que "As obrigações referentes à confidencialidade, proteção de dados pessoais e propriedade intelectual estabelecidas neste contrato subsistirão ao término da relação de emprego, as quais permanecerão em vigor por prazo indeterminado".
- O controle de devolução é feito mediante consulta ao dossiê do funcionário para identificar os ativos que precisam ser devolvidas, onde o RH informa ao NOC. O Analista de TI atualiza o GLPI em relação à devolução. No caso dos celulares, os aparelhos devolvidos ficam com o RH.

Riscos: 2.3 a 2.5; 7.3

Responsável pelo controle: Recursos Humanos

Forma de monitoramento: Auditorias internas do SGSI

A.6.06 Acordos de confidencialidade ou não divulgação

Acordos de confidencialidade ou não divulgação que reflitam as necessidades da organização para a proteção das informações devem ser identificados, documentados, analisados criticamente em intervalos regulares e assinados pelo pessoal e por outras partes interessadas pertinentes.

Situação atual:

- Justificativa para inclusão: a formalização dos termos e condições relacionadas à confidencialidade ou não divulgação contribui para a transparência nas relações e traz maior segurança jurídica para ambas as partes.
- O funcionários assinam o Contrato de observância à Lei Geral de Proteção de Dados, Confidencialidade e Propriedade Intelectual, com as regras aplicáveis.
- No Termo de confidencialidade há previsão de não divulgar as informações confidenciais da empresa após o encerramento da contratação.

Riscos: 6.14, 6.15; 7.9 a 7.12

Responsável pelo controle: Recursos Humanos

Forma de monitoramento: Auditorias internas do SGSI

A.6.07 Trabalho remoto

Medidas de segurança devem ser implementadas quando as pessoas estiverem trabalhando remotamente para proteger as informações acessadas, tratadas ou armazenadas fora das instalações da organização.

Situação atual:

- Justificativa para inclusão: a prática de trabalho remoto, de forma contínua ou pontual, ocorre na organização e traz riscos tais como o vazamento de informações para pessoas de fora da organização e perda ou roubo de ativos (dispositivos móveis, como laptops e smartphones).
- É utilizado o Termo aditivo ao contrato de trabalho para a validação do home office, com a seção 4 deste documento destinada à Segurança da Informação e Dados Corporativos.

Riscos: 7.12 a 7.14

Responsável pelo controle: Comitê de Segurança da Informação

Forma de monitoramento: Análise crítica independente da segurança da informação

A.6.08 Relato de eventos de segurança da informação

A organização deve fornecer um mecanismo para que as pessoas relatem eventos da segurança da informação observados ou suspeitos por meio de canais apropriados em tempo hábil.

Situação atual:

- Justificativa para inclusão: sem um canal adequado para o relato de eventos de segurança da informação, há riscos relacionados ao tratamento de incidentes, tais como o atraso no tratamento e a falta de tratamento por ausência de comunicação. Além disso, pode ser difícil aprender com os incidentes e melhorar a segurança da organização no futuro caso não haja o relato e tratamento adequados.
- A obrigatoriedade para que as pessoas relatem eventos da segurança da informação está prevista no Termo aditivo ao contrato de trabalho para a validação do home office.

- O item 5.1 do PG-15 (Tratamento de incidentes de Segurança da Informação) define o canal de comunicação utilizado para relatos de eventos.

Riscos: Todos os riscos relacionados na matriz de riscos

Responsável pelo controle: SOC

Forma de monitoramento: Análise crítica independente da segurança da informação

A07 - Controles físicos

A.7.01 Perímetros de segurança física

Perímetros de segurança devem ser definidos e usados para proteger áreas que contenham informações e outros ativos associados.

Situação atual:

- Justificativa para inclusão: A definição dos perímetros é necessária para que os controles aplicados em cada um deles seja proporcional à importância dos ativos de informação existentes em cada local.
- Existem os seguintes perímetros principais de interesse para a segurança da informação: 1) área entre o muro e a edificação (onde se localiza o gerador de energia, tubulação externa de cabeamento de dados e energia e condensadores do ar condicionado do Data Center), 2) Áreas de convivência (recepção, copa, piscina) 3) Salas de trabalho e 4) Container do Data Center.

Riscos: 4.3 a 4.5, 4.10 a 4.12; 6.1

Responsável pelo controle: Diretoria Técnica

Forma de monitoramento: Monitoramento eletrônico terceirizado e Câmeras

A.7.02 Entrada física

As áreas seguras devem ser protegidas por controles de entrada e pontos de acesso apropriados.

Situação atual:

- A sala do Data Center é protegida por acesso mediante leitura biométrica (facial e digital). Dentro do Data Center há câmera de monitoramento.
- Justificativa para inclusão: os espaços físicos designados para proteger ativos de informação sensíveis ou críticos devem ter sua entrada restrita a pessoas autorizadas para reduzir riscos tais como: acesso indevido a informações, roubo de informações e danos (intencionais ou não) aos ativos.
- A sala do Data Center é protegida por acesso mediante leitura biométrica (facial e digital). Dentro do Data Center há câmera de monitoramento e sensor de fumaça.

Riscos: 4.3 a 4.5, 4.10 a 4.12; 6.1

Responsável pelo controle: Gerente de NOC/Suporte

Forma de monitoramento: Check-List de monitoramento de controles físicos

A.7.03 Segurança de escritórios, salas e instalações

Segurança física para escritórios, salas e instalações deve ser projetada e implementada.

Situação atual:

- Justificativa para inclusão: escritórios, salas e instalações são ambientes onde as atividades operacionais e administrativas são realizadas e, portanto, processam informações. A segurança física apropriada ao tipo de ativos de informação presentes nestes ambientes é necessária para minimizar riscos.
- Há monitoramento ativo por sensores de presença por empresa de vigilância eletrônica (Ativa Locacao, Comercio e Serviços de Sistemas Eletrônicos Ltda. - <https://ativa24h.com.br/> CNPJ 14.045.836/0001-17)

Riscos: 4.3 a 4.5, 4.10 a 4.12; 6.1

Responsável pelo controle: Coordenadores ou Gerentes

Forma de monitoramento: Análise crítica independente da segurança da informação

A.7.04 Monitoramento de segurança física

As instalações devem ser monitoradas continuamente para acesso físico não autorizado.

Situação atual:

- Justificativa para inclusão: O monitoramento da segurança física pode ajudar a mitigar riscos tais como roubo de equipamentos, tentativas de acesso não autorizado aos locais onde estão os ativos de informação, ataques de segurança da informação envolvem o uso de equipamentos físicos, como dispositivos USB infectados e sabotagem.
- Há câmeras (CFTV) instaladas em vários ambientes.
- Alarmes baseados nos sensores de presença são monitorados em tempo real por empresa terceirizada (Ativa Locacao, Comercio e Servicos de Sistemas Eletronicos Ltda. - <https://ativa24h.com.br/> CNPJ 14.045.836/0001-17), fora do horário administrativo.

Riscos: 4.3 a 4.5, 4.10 a 4.12; 6.1

Responsável pelo controle: Diretoria Técnica

Forma de monitoramento: Monitoramento eletrônico terceirizado

A.7.05 Proteção contra ameaças físicas e ambientais

Proteção contra ameaças físicas e ambientais, como desastres naturais e outras ameaças físicas intencionais ou não intencionais à infraestrutura, deve ser projetada e implementada.

Situação atual:

- Justificativa para inclusão: ameaças físicas e ambientais podem causar interrupções nos serviços, perda de dados, impacto financeiro e reputacional para a organização. A combinação de ações preventivas e de mitigação de danos é necessária para reduzir os impactos negativos.
- A sede da empresa fica localizada em um bairro predominantemente residencial, que não possui histórico relevantes de furtos, assaltos ou vandalismo. Também não há histórico de alagamentos ou outros eventos naturais.
- Há extintores de incêndio, com controle anual de recargas.
- Dentro do Data Center há sensor de fumaça associado a um controle infravermelho para adequação dinâmica da climatização no Data Center.

Riscos: 2.6 a 2.8, 2.11, 2.12; 4.6 a 4.9, 4.15

Responsável pelo controle: Diretoria Técnica

Forma de monitoramento: Check-List de monitoramento de controles físicos

A.7.07 Mesa limpa e tela limpa

Regras de mesa limpa para documentos impressos e mídia de armazenamento removível e regras de tela limpa para os recursos de tratamento das informações devem ser definidas e adequadamente aplicadas.

Situação atual:

- Justificativa para inclusão: a aplicação destas regras contribui para a proteção de informações confidenciais, retirando-as da vista imediata de pessoas não autorizadas, ajuda a prevenir roubos de informação e reduz a exposição das pessoas a ataques de engenharia social.
- A IT-04 (Uso aceitável de Ativos) define regras para evitar exposição de informações em telas, mesas e impressoras.

Riscos: 6.1; 7.3, 7.12

Responsável pelo controle: Coordenadores ou Gerentes

Forma de monitoramento: Análise crítica independente da segurança da informação

A.7.08 Localização e proteção de equipamentos

Os equipamentos devem ser posicionados com segurança e proteção.

Situação atual:

- Justificativa para inclusão: a localização adequada dos equipamentos e sua proteção reduz os riscos de acesso indevido a informações e perdas por danos ou furtos.
- Não foi identificada nenhuma necessidade de reposicionamento de equipamentos e/ou implementação de medidas para garantir privacidade na informação.

Riscos: 6.1; 7.3, 7.12

Responsável pelo controle: Coordenadores ou Gerentes

Forma de monitoramento: Análise crítica independente da segurança da informação

A.7.10 Mídia de armazenamento

As mídias de armazenamento devem ser gerenciadas por seu ciclo de vida de aquisição, uso, transporte e descarte, de acordo com o esquema de classificação e com os requisitos de manuseio da organização.

Situação atual:

- Justificativa para inclusão: As mídias de armazenamento podem conter informações importantes, que precisam ser protegidas com base nas políticas internas. O gerenciamento do ciclo de vida é importante para manter a segurança da informação.
- O Anexo 2 da IT-03 (Classificação, rotulagem e manuseio de informação), apresenta os métodos para descarte das informações, incluindo mídias físicas de armazenamento.
- Todos os equipamentos vinculados ao Active Directory possuem a USB desabilitada para dados.
- Todas as mídias de armazenamento são adquiridas como originais.

Riscos: 2.3 a 2.5; 6.14, 6.15; 7.3

Responsável pelo controle: Analista de TI

Forma de monitoramento: Análise crítica independente da segurança da informação

A.7.11 Serviços de infraestrutura

As instalações de tratamento de informações devem ser protegidas contra falhas de energia e outras interrupções causadas por falhas nos serviços de infraestrutura.

Situação atual:

- Justificativa para inclusão: falhas nos serviços de infraestrutura podem causar interrupção no funcionamento das instalações de tratamento de informações, afetando negativamente o público interno e os clientes.
- Há dois No-breaks que protegem os ativos de rede do Data Center e outro No-break para os racks (que alimentam rede cabeada, controles de acesso, wifi e câmeras), com troca de baterias a cada 2 anos.
- A empresa possui gerador que atua no caso de interrupção no fornecimento de energia elétrica.
- O Plano de Contingência (PL-02) aborda as ações para falha no fornecimento de energia elétrica pela concessionária e o PL-04 trata da indisponibilidade de operadores da internet.

Riscos: 4.6 a 4.9, 4.15

Responsável pelo controle: Administrador de redes

Forma de monitoramento: Monitoramento via Zabbix

A.7.12 Segurança do cabeamento

Os cabos que transportam energia ou dados, ou que sustentam serviços de informação, devem ser protegidos contra interceptação, interferência ou danos.

Situação atual:

- Justificativa para inclusão: os cabos que transportam energia ou dados são ativos que podem afetar de modo importante a segurança da informação caso sejam danificados ou caso haja ataques com objetivo de acessar informações ou afetar sua integridade. A segurança no cabeamento, portanto, contribui para evitar a interrupção nas atividades e preservar a confidencialidade, integridade e disponibilidade das informações.
- Fisicamente, os cabos de rede são instalados em canaletas dutotec que permitem o caminho de cabos de energia e de dados sem interferência.

Riscos: 5.7, 5.8, 5.12, 5.17, 5.18

Responsável pelo controle: Analista de TI

Forma de monitoramento: Análise crítica independente da segurança da informação

A.7.13 Manutenção de equipamentos

Os equipamentos devem ser mantidos corretamente para assegurar a disponibilidade, integridade e confidencialidade da informação.

Situação atual:

- Justificativa para inclusão: A manutenção de equipamentos é necessária para reduzir o risco de indisponibilidade indevida e as consequências negativas para os sistemas de informação.

- Equipamentos incluem ar condicionado do Data Center, geradores e nobreaks/baterias. O planejamento e o registro das atividades de manutenção preventiva é feito através do Bitrix24, onde as tarefas são configuradas de forma recorrente, conforme periodicidade.
- A empresa mantém uma Planilha de controle de manutenção preventiva com a lista de equipamentos, criticidade, periodicidade e tipo de intervenção a ser realizada.

Riscos: 2.9 a 2.12; 4.1, 4.2, 4.13 a 4.15

Responsável pelo controle: Gerente de Implantação e manutenção

Forma de monitoramento: Auditorias internas do SGSI

A.7.14 Descarte seguro ou reutilização de equipamentos

Os itens dos equipamentos que contenham mídia de armazenamento devem ser verificados para assegurar que quaisquer dados confidenciais e software licenciado tenham sido removidos ou substituídos com segurança antes do descarte ou reutilização.

Situação atual:

- Justificativa para inclusão: Evitar o vazamento de informações por equipamento que seja descartado ou reutilizado e que contenha mídia de armazenamento.
- Os HDs são removidos dos computadores que possuem o uso descontinuado.
- O Anexo 2 da IT-03 (Classificação, rotulagem e manuseio de informação), apresenta os métodos para descarte das informações, incluindo mídias físicas de armazenamento.

Riscos: 2.3 a 2.5; 6.14, 6.15; 7.3

Responsável pelo controle: Analista de TI

Forma de monitoramento: Análise crítica independente da segurança da informação

A08 - Controles tecnológicos

A.8.01 Dispositivos endpoint do usuário

As informações armazenadas, tratadas ou acessíveis por meio de dispositivos endpoint do usuário devem ser protegidas.

Situação atual:

- Justificativa para inclusão: Alguns dispositivos endpoint estão mais expostos a ataques diretos devido à sua conectividade com a Internet, uso em redes Wi-Fi públicas e possibilidade de maior interação com conteúdos não confiáveis. Além disso, a natureza portátil de parte desses dispositivos aumenta o risco de perda física e roubo, o que pode resultar em acesso não autorizado a informações sensíveis.
- Os dispositivos são constituídos principalmente por notebooks, desktops e smartphones. Há também uma tela interativa com sistema android e windows utilizada para apresentações.
- As proteções associadas incluem a atribuição de direitos de acesso (ver controle A.5.18) e proteções contra malware (ver controle A.8.07).
- Os funcionários assinam termos contendo especificações de segurança da informação quando recebem dispositivos endpoint (notebooks e smartphones).

Riscos: 2.1 a 2.5, 2.13, 2.14; 3.1 a 3.3, 3.6 a 3.10; 5.1 a 5.3, 5.12 a 5.14, 5.21, 5.22; 6.1, 6.9

Responsável pelo controle: Coordenadores ou Gerentes

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.02 Direitos de acessos privilegiados

A atribuição e o uso de direitos de acessos privilegiados devem ser restritos e gerenciados.

Situação atual:

- Justificativa para inclusão: o gerenciamento dos direitos de acesso ajuda a garantir que apenas usuários autorizados tenham acesso aos dados e sistemas da organização.
- Direitos de acesso são gerenciados através do Active Directory e em cada aplicação específica.

Riscos: 1.21 a 1.27; 3.1 a 3.3; 5.12 a 5.14; 6.1; 7.3 a 7.5

Responsável pelo controle: Gerente de NOC/Suporte

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.03 Restrição de acesso à informação

O acesso às informações e a outros ativos associados deve ser restrito de acordo com a política específica por tema sobre controle de acesso.

Situação atual:

- Justificativa para inclusão: Informações classificadas (ver A.5.12) como confidenciais ou graus mais elevados não podem ser acessadas por pessoas não autorizadas.
- O acesso à informação depende dos direitos de acesso. Informações restritas, tais como informações do RH, informações financeiras etc. são acessadas apenas por usuários autorizados.

Riscos: 1.21 a 1.27; 3.1 a 3.3; 5.12 a 5.14; 6.1; 7.3 a 7.5

Responsável pelo controle: Coordenadores ou Gerentes

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.05 Autenticação segura

Tecnologias e procedimentos de autenticação seguros devem ser implementados, com base em restrições de acesso à informação e à política específica por tema de controle de acesso.

Situação atual:

- Justificativa para inclusão: a autenticação é necessária para determinar se a pessoa que está tentando acessar um ativo de informação está realmente autorizada e cadastrada para tanto, de forma a evitar riscos à segurança da informação.
- As regras para senhas estão descritas na IT-05 (Gestão de Identidade e Acesso aos ativos).

Riscos: 3.1 a 3.3; 4.3 a 4.5, 4.10 a 4.12; 5.3, 5.12 a 5.14, 5.31, 5.32; 6.1; 7.3

Responsável pelo controle: Administrador de sistemas

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.06 Gestão de capacidade

O uso dos recursos deve ser monitorado e ajustado de acordo com os requisitos atuais e esperados de capacidade.

Situação atual:

- Justificativa para inclusão: a gestão da capacidade é fundamental para garantir a disponibilidade (por exemplo, evitando sobrecargas, gargalos e interrupções que possam comprometer a segurança dos sistemas), eficiência, desempenho e adaptabilidade (por exemplo, ajuda a identificar os limites dos recursos e a definir níveis de capacidade de contingência necessários para lidar com eventos inesperados) dos recursos de proteção. Ela contribui para manter a integridade, confidencialidade e disponibilidade dos dados e sistemas em face das ameaças em constante evolução.
- Para o escopo do SGSI, a capacidade atual de atendimento do SOC é suficiente para suprir as demandas.

Riscos: 1.17 a 1.20; 5.4 a 5.6, 5.15, 5.16; 7.8

Responsável pelo controle: Gerente de NOC/Suporte

Forma de monitoramento: Auditorias internas do SGSI

A.8.07 Proteção contra Malware

Proteção contra malware deve ser implementada e apoiada pela conscientização adequada do usuário.

Situação atual:

- Justificativa para inclusão: malwares desempenham um papel significativo em atividades cibernéticas maliciosas e são uma das principais ameaças à segurança da informação nos ambientes digitais.
- É utilizado o Kaspersky para proteção contra malware e um serviço anti-DDoS baseado em análise de tráfego que detecta anomalias (Huge).

Riscos: 3.11, 3.12; 5.4 a 5.6, 5.21, 5.22, 5.29 a 5.31; 6.1; 7.15 e 7.16

Responsável pelo controle: SOC

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.08 Gestão de vulnerabilidades técnicas

Informações sobre vulnerabilidades técnicas dos sistemas de informação em uso devem ser obtidas; a exposição da organização a tais vulnerabilidades deve ser avaliada e medidas apropriadas devem ser tomadas.

Situação atual:

- Justificativa para inclusão: a gestão de vulnerabilidades técnicas deve ser realizada para identificar as possíveis fragilidades que podem ser exploradas por ameaças.
- O PG-08 prevê a análise sobre novas vulnerabilidades técnicas que eventualmente possa ser trazidas em mudanças.
- Há base de conhecimento no Bitrix e Osiris para o grupo do SOC.

Riscos: Todos os riscos relacionados na matriz de riscos

Responsável pelo controle: Comitê de Segurança da Informação

Forma de monitoramento: Reuniões periódicas do Comitê de Segurança da Informação.

A.8.09 Gestão de configuração

As configurações, incluindo configurações de segurança, de hardware, software, serviços e redes, devem ser estabelecidas, documentadas, implementadas, monitoradas e analisadas criticamente.

Situação atual:

- Justificativa para inclusão: Para garantir a segurança dos sistemas, é fundamental que tanto o hardware quanto o software, serviços e redes estejam configurados de forma adequada. Isso inclui a implementação das configurações de segurança necessárias e a adoção de controles efetivos para evitar qualquer alteração não autorizada ou incorreta nessas configurações.
- O procedimento de gestão de configuração (PG - 16) define a sistemática para tratamento dos itens de configuração. Este procedimento traz aspectos de Segurança da Informação.
- A gestão de inventário é também utilizada para registro das configuração.
- A ferramenta oxidized funciona como backup de configuração de ativos de rede.

Riscos: 1.1, 1.2; 2.2, 2.2; 5.25, 5.26

Responsável pelo controle: Analista de TI

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.10 Exclusão de informações

As informações armazenadas em sistemas de informação, dispositivos ou em qualquer outra mídia de armazenamento devem ser excluídas quando não forem mais necessárias.

Situação atual:

- Justificativa para inclusão: é necessária para evitar a exposição desnecessária de informações sensíveis e estar em compliance com requisitos legais (Ex.: LGPD), estatutários, regulamentares e contratuais para a exclusão de informações. Além disso, é importante que informações sensíveis não sejam mantidas por mais tempo do que é necessário para reduzir o risco de divulgação indesejável.
- O quadro de controle de registros e dados pessoais estabelece o prazo de retenção de informações, prevendo as disposições ao final do período.
- O Anexo 2 da IT-03 (Classificação, rotulagem e manuseio de informação) estabelece os métodos de descarte para informações armazenadas eletronicamente.

Riscos: 2.3 a 2.5; 6.14, 6.15; 7.3

Responsável pelo controle: Coordenadores ou Gerentes

Forma de monitoramento: Auditorias internas do SGSI

A.8.11 Mascaramento de dados

O mascaramento de dados deve ser usado de acordo com a política específica por tema da organização sobre o controle de acesso e outros requisitos específicos por tema relacionados e requisitos de negócios, levando em consideração a legislação aplicável.

Situação atual:

- Justificativa para inclusão: O mascaramento de dados é necessário para limitar a exposição de dados confidenciais nas seguintes situações: Senhas de soluções e aplicações como Bitrix, Active Directory etc.
- Senhas armazenadas não conseguem ser visualizadas mesmo para pessoas com acesso privilegiado.

Riscos: 3.3; 5.12 a 5.14; 6.1; 7.3

Responsável pelo controle: Analista de TI

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.12 Prevenção de vazamento de dados

As medidas de prevenção de vazamento de dados devem ser aplicadas a sistemas, redes e quaisquer outros dispositivos que tratem, armazenem ou transmitam informações sensíveis.

Situação atual:

- Justificativa para inclusão: A detecção e prevenção da divulgação e extração não autorizadas de informações por indivíduos ou sistemas é fundamental para evitar os riscos de violação da confidencialidade de informações classificadas.
- A IT-03 (Classificação da informação) define 3 níveis de classificação (Pública, de Uso Interno e Confidencial). Para cada um dos níveis de classificação a Tabela do Anexo 1 define as formas de lidar com a informação.
- Nos equipamentos internos, o uso de dispositivos acessíveis a partir de portas USB é bloqueado, o que restringe a capacidade do usuário de copiar e colar ou carregar dados por estes meios.
- O trabalho remoto faz uso de VPN.

Riscos: 2.3 a 2.5, 2.13, 2.14; 3.1 a 3.4, 3.6, 3.7; 5.3, 5.9; 6.1

Responsável pelo controle: Administrador de redes

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.13 Backup das informações Cópias de backup de informações, software e sistemas devem ser mantidas e testadas regularmente de acordo com a política específica por tema acordada sobre backup.

Situação atual:

- Justificativa para inclusão: a realização de cópias de segurança é necessária para a recuperação de informações em incidentes de perda de dados ou sistemas.
- Backups de máquinas virtuais são gerenciados através do Proxmox, através de rotinas pré-configuradas. Há envio automático de e-mails com o status da realização do backup (sucesso/falha).
- A ferramenta oxidized funciona como backup de configuração.

Riscos: 3.08 a 3.10

Responsável pelo controle: Analista de TI

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.14 Redundância dos recursos de tratamento de informações Os recursos de tratamento de informações devem ser implementados com redundância suficiente para atender aos requisitos de disponibilidade.

Situação atual:

- Justificativa para inclusão: A redundância de recursos de tratamento de informações é uma prática importante para garantir a disponibilidade contínua dos sistemas e dados.
- Há redundância nos seguintes casos:
 - Core: Alguns serviços do DataCenter possuem redundância no POP Lagoa Seca, há redundância de ar condicionado e de BGP;
 - Backbone: a topologia em anel com o protocolo MPLS permite a redundância no fornecimento do sinal aos clientes;
 - Alimentação de energia elétrica para o core;
 - Gerador, banco de baterias para o core e para POPs e ERBs.

Riscos: 1.11; 2.6 a 2.8, 2.17, 2.18; 3.8 a 3.10; 4.1, 4.2, 4.6, 4.7, 4.15; 5.18; 5.23

Responsável pelo controle: Diretoria Técnica

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.15 Log Logs que registrem atividades, exceções, falhas e outros eventos relevantes devem ser produzidos, armazenados, protegidos e analisados.

Situação atual:

- Justificativa para inclusão: registrar eventos, gerar evidências, assegurar a integridade das informações de registro, prevenir contra acesso não autorizado, identificar eventos de segurança da informação que possam levar a um incidente de segurança da informação e apoiar investigações.

- A IT-10 (Política de Logs) traz as diretrizes e procedimentos para a criação, manutenção, utilização e exclusão de registros de logs em sistemas e aplicativos.

Riscos: 3.5

Responsável pelo controle: Administrador de redes e SOC

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.16 Atividades de monitoramento

As redes, sistemas e aplicações devem ser monitorados por comportamentos anômalos e por ações apropriadas, tomadas para avaliar possíveis incidentes de segurança da informação.

Situação atual:

- Justificativa para inclusão: a detecção de comportamentos anômalos e possíveis incidentes de segurança da informação é essencial para agir tempestivamente e evitar ou mitigar impactos negativos associados à segurança das informações.
- Comportamentos anômalos são identificados por sistemas de monitoramento como: Zabbix, Wazuh, Karspersky etc., além de notificações por meio de formulário eletrônico (QR Code), e-mail para o soc@evostec.com.br, CERT.br e AbuseIPDB.com.

Riscos: Riscos relacionados ao grupo de ativos 5

Responsável pelo controle: Analista de TI e SOC

Forma de monitoramento: Reuniões periódicas do Comitê de Segurança da Informação

A.8.17 Sincronização do relógio

Os relógios dos sistemas de tratamento de informações utilizados pela organização devem ser sincronizados com fontes de tempo aprovadas.

Situação atual:

- Justificativa para inclusão: A sincronização do relógio é fundamental para o gerenciamento adequado de logs de segurança, sendo essencial para a análise forense de segurança e investigações em caso de incidentes de segurança.
- A sincronização dos relógios faz parte das políticas dentro do Active Directory que abrange os computadores.

Riscos: 3.5

Responsável pelo controle: Administrador de redes

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.18 Uso de programas utilitários privilegiados

O uso de programas utilitários que possam ser capazes de substituir os controles de sistema e as aplicações deve ser restrito e rigorosamente controlado.

Situação atual:

- Justificativa para inclusão: Programas utilitários são essenciais para a administração e o gerenciamento de sistemas de informação, mas podem apresentar riscos se mal utilizados ou explorados por indivíduos mal-intencionados. Portanto, é importante implementar controles adequados para garantir que apenas usuários autorizados possam acessar e executar esses programas.

- O acesso ao Active Directory, Ferramentas de backup e restauração é feito apenas pelos analistas de TI do NOC.

Riscos: 1.21 a 1.27; 3.1 a 3.3; 5.12 a 5.14; 7.3 a 7.5

Responsável pelo controle: Analista de TI

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.19 Instalação de software em sistemas operacionais

Procedimentos e medidas devem ser implementados para gerenciar com segurança a instalação de software em sistemas operacionais.

Situação atual:

- Justificativa para inclusão: Esse controle é necessário para assegurar a integridade dos sistemas operacionais e evitar a exploração de vulnerabilidades técnicas.
- As instalações das atualizações de patches de segurança no Windows, é habilitada por padrão. O Kaspersky monitora a necessidade de atualização para softwares instalados nos dispositivos nos usuários.
- Para os servidores, há prática de restringir as versões de atualização do tipo LTS (Versões de suporte de longo período) do Linux, que só podem ser instaladas pelo Administrador do Sistema.

Riscos: 1.21 a 1.27; 3.1 a 3.3; 5.12 a 5.14; 7.3 a 7.5

Responsável pelo controle: Analista de TI

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.20 Segurança de redes

Redes e dispositivos de rede devem ser protegidos, gerenciados e controlados para proteger as informações em sistemas e aplicações.

Situação atual:

- Justificativa para inclusão: O controle é necessário para assegurar a segurança das informações nas redes e para proteger os serviços conectados de acesso não autorizado.
- As responsabilidades pela gestão de equipamentos e dispositivos de rede é do Administrador de Redes na camada de borda (BGP) e os analistas de TI (NOC) para backbone, backhaul e rede interna.
- Os principais procedimentos para gestão de equipamentos e dispositivos de rede incluem as proteções do endpoint (ver A.8.01) uso de firewall de borda, Anti-DDoS, monitoramento através do Zabbix, controles de acesso físico. O Servidor de DHCP detecta a entrada de dispositivos à rede através da entrega de IPs.
- A documentação da rede (física e lógica) está atualizada e documentada através do sistema Netbox.

Riscos: Riscos relacionados ao grupo de ativos 5

Responsável pelo controle: Administrador de redes

Forma de monitoramento: Reuniões periódicas do Comitê de Segurança da Informação

A.8.21 Segurança dos serviços de rede

Mecanismos de segurança, níveis de serviço e requisitos de serviços de rede devem ser identificados, implementados e monitorados.

Situação atual:

- Justificativa para inclusão: Durante o fluxo de informações entre a entidade demandante (cliente) e o fornecedor do serviço de rede (servidor) pode haver vulnerabilidades que, se exploradas, comprometerão a segurança da informação. Como todas as organizações, há uma série de serviços de rede que são utilizados, de forma que é necessário gerenciá-los do ponto de vista da segurança da informação.
- Os mecanismos de segurança existentes estão descritos em outros controles desta SoA (Ex.: controles de acesso, de autenticação, criptografia etc.).

Riscos: Riscos relacionados ao grupo de ativos 5

Responsável pelo controle: Administrador de redes

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.22 Segregação de redes

Grupos de serviços de informação, usuários e sistemas de informação devem ser segregados nas redes da organização.

Situação atual:

- Justificativa para inclusão: A segmentação de rede limita o movimento lateral de ataques em potencial, isola sistemas e dados sensíveis, e ajuda a evitar a propagação de ameaças.
- A segregação da rede, no âmbito da sede, é feita baseada nos negócios: uma rede para a Zaori, outra para as unidades de apoio, Mesotech e EVOS, cada uma com sua vLAN segregando-as. Também há segregação de usuário externo em redes wifi.

Riscos: 3.1 a 3.3; 5.1 a 5.3, 5.9 a 5.14; 6.1; 7.3, 7.12 a 7.14

Responsável pelo controle: Administrador de redes

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.23 Filtragem da Web

O acesso a sites externos deve ser gerenciado para reduzir a exposição a conteúdo malicioso.

Situação atual:

- Justificativa para inclusão: evita o acesso a sites maliciosos conhecidos, como sites de phishing, distribuição de malware, fraudes online e outros conteúdos perigosos. Além disso, também contribui para a produtividade, evitando o acesso a sites não relacionados ao trabalho e a atividades online não produtivas durante o horário de trabalho.
- A filtragem da Web está definida na IT-06 (Internet e mídias sociais).

Riscos: 5.1, 5.2, 5.21, 5.22

Responsável pelo controle: Administrador de redes

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.24 Uso de criptografia

Regras para o uso efetivo da criptografia, incluindo o gerenciamento de chaves criptográficas devem ser definidas e implementadas.

Situação atual:

- Justificativa para inclusão: o controle é necessário para impedir que pessoas não autorizadas obtenham informações confidenciais, mesmo se conseguirem acessar ou interceptar os dados. Também é importante para assegurar o não-repúdio em alguns casos, ou seja para provar a ocorrência de um evento ou ação alegados e suas entidades originárias.

- A IT-06 (Internet e mídias sociais) traz as diretrizes para uso de criptografia na empresa.

Riscos: 5.9, 5.11, 5.32; 6.1; 7.12

Responsável pelo controle: Administrador de sistemas

Forma de monitoramento: Análise crítica independente da segurança da informação

A.8.26 Requisitos de segurança da aplicação

Requisitos de segurança da informação devem ser identificados, especificados e aprovados ao desenvolver ou adquirir aplicações.

Situação atual:

- Justificativa para inclusão: A empresa não desenvolve aplicações, porém os requisitos de segurança precisam ser especificados e aprovados antes da aquisição das aplicações desenvolvidas por terceiros. Deve ser ressaltado que aplicações acessíveis por redes estão sujeitas a uma série de ameaças relacionadas à rede, como atividades fraudulentas, disputas contratuais ou divulgação de informações ao público; transmissão incompleta, roteamento errado, alteração não autorizada de mensagem, duplicação ou repetição.
- Requisitos aplicados aos fornecedores descritos no item 6 do PG-14 (Relacionamento com fornecedores) trazem, implicitamente requisitos para a aquisição de aplicações.

Riscos: 1.12 a 1.19; 6.14, 6.15

Responsável pelo controle: Gerente de NOC/Suporte

Forma de monitoramento: Auditorias internas do SGSI

A.8.32 Gestão de mudanças

Mudanças nos recursos de tratamento de informações e sistemas de informação devem estar sujeitas a procedimentos de gestão de mudanças.

Situação atual:

- Justificativa para inclusão: O planejamento adequado de uma mudança é importante para evitar consequências negativas decorrentes da introdução de novos sistemas e grandes mudanças nos sistemas existentes, levando em conta que o controle inadequado das mudanças nos recursos de tratamento de informações e sistemas de informação é uma causa comum de falhas de sistema ou segurança.
- O PG-08 (Gestão de Mudanças) traz a sistemática para tratamento e registro de mudanças e inclui a abordagem à segurança da informação.

Riscos: Todos os riscos relacionados na matriz de risco

Responsável pelo controle: Gerente de NOC/Suporte

Forma de monitoramento: Auditorias internas do SGSI

F. Controles não aplicáveis

A05 - Controles organizacionais

- A.5.08 Segurança da informação no gerenciamento de projetos** A segurança da informação deve ser integrada ao gerenciamento de projetos.

Justificativa:

- Os projetos de implementação de novos serviços não são aplicáveis ao escopo do SGSI.

A07 - Controles físicos

- A.7.06 Trabalho em áreas seguras** Medidas de segurança para trabalhar em áreas seguras devem ser projetadas e implementadas.

Justificativa:

- Não há atividades regulares/contínuas no Data Center. Os controles descritos para A.7.02 são suficientes.

- A.7.09 Segurança de ativos fora das instalações da organização** Os ativos fora das instalações da organização devem ser protegidos.

Justificativa:

- O escopo do SGSI não contempla ativos localizados fora das instalações da organização.

A08 - Controles tecnológicos

- A.8.04 Acesso ao código-fonte** Os acessos de leitura e escrita ao código-fonte, ferramentas de desenvolvimento e bibliotecas de software devem ser adequadamente gerenciados.

Justificativa:

- Na atual configuração de atividades a serem desenvolvidas no âmbito do SOC, não é necessário acessar códigos fonte, seja para aplicações internas ou para investigação de incidentes de segurança envolvendo códigos-fonte.

- A.8.25 Ciclo de vida de desenvolvimento seguro** Regras para o desenvolvimento seguro de software e sistemas devem ser estabelecidas e aplicadas.

Justificativa:

- Dentro do escopo do SGSI, a organização não realiza atividade de desenvolvimento de sistemas de informações.

- A.8.27 Princípios de arquitetura e engenharia de sistemas seguros** Princípios de engenharia de sistemas seguros devem ser estabelecidos, documentados, mantidos e aplicados a qualquer atividade de desenvolvimento de sistemas.

Justificativa:

- Dentro do escopo do SGSI, a organização não realiza atividade de desenvolvimento de sistemas de informações.

- A.8.28 Codificação segura** Princípios de codificação segura devem ser aplicados ao desenvolvimento de software.

Justificativa:

- Dentro do escopo do SGSI, a organização não realiza atividade de desenvolvimento de sistemas de informações.

- A.8.29 Testes de segurança em desenvolvimento e aceitação** Processos de teste de segurança devem ser definidos e implementados no ciclo de vida do desenvolvimento.

Justificativa:

- Dentro do escopo do SGSI, a organização não realiza atividade de desenvolvimento de software.

- A.8.30 Desenvolvimento terceirizado** A organização deve dirigir, monitorar e analisar criticamente as atividades relacionadas à terceirização de desenvolvimento de sistemas.

Justificativa:

- Na atual configuração de atividades a serem desenvolvidas no âmbito do SOC, não é prevista a contratação de desenvolvimento de sistemas. Desta forma, não há riscos associados a este tema.

A.8.31 Separação dos ambientes de desenvolvimento, teste e produção

Ambientes de desenvolvimento, testes e produção devem ser separados e protegidos.

Justificativa:

- Dentro do escopo do SGSI, a organização não realiza atividade de desenvolvimento de sistemas de informações.

A.8.33 Informações de teste

Informações de teste devem ser adequadamente selecionadas, protegidas e gerenciadas.

Justificativa:

- Na atual configuração de atividades a serem desenvolvidas no âmbito do SOC, não é prevista a realização testes de sistemas e avaliação de sistemas operacionais.

A.8.34 Proteção de sistemas de informação durante os testes de auditoria

Testes de auditoria e outras atividades de garantia envolvendo a avaliação de sistemas operacionais devem ser planejados e acordados entre o testador e a gestão apropriada.

Justificativa:

- Na atual configuração de atividades a serem desenvolvidas no âmbito do SOC, não é prevista a realização testes de sistemas e avaliação de sistemas operacionais.

G. Lista de controles por responsável

Administrador de redes

A.7.11	Serviços de infraestrutura
A.8.12	Prevenção de vazamento de dados
A.8.15	Log
A.8.17	Sincronização do relógio
A.8.20	Segurança de redes
A.8.21	Segurança dos serviços de rede
A.8.22	Segregação de redes
A.8.23	Filtragem da Web

Administrador de sistemas

A.8.05	Autenticação segura
A.8.24	Uso de criptografia

Analista de TI

A.5.09	Inventário de informações e outros ativos associados
A.5.11	Devolução de ativos
A.5.12	Classificação das informações
A.5.13	Rotulagem de informações
A.5.16	Gestão de identidade
A.5.17	Informações de autenticação
A.5.21	Gestão da segurança da informação na cadeia de fornecimento de TIC
A.7.10	Mídia de armazenamento
A.7.12	Segurança do cabeamento
A.7.14	Descarte seguro ou reutilização de equipamentos
A.8.09	Gestão de configuração
A.8.11	Mascaramento de dados
A.8.13	Backup das informações
A.8.16	Atividades de monitoramento
A.8.18	Uso de programas utilitários privilegiados
A.8.19	Instalação de software em sistemas operacionais

Assessoria Jurídica

A.5.20	Abordagem da segurança da informação nos contratos de fornecedores
--------	--

Comitê de Segurança da Informação

A.5.02	Papéis e responsabilidades pela segurança da informação
A.5.10	Uso aceitável de informações e outros ativos associados
A.5.19	Segurança da informação nas relações com fornecedores
A.5.29	Segurança da informação durante a interrupção
A.5.30	Prontidão de TIC para continuidade de negócios
A.5.31	Requisitos legais, estatutários, regulamentares e contratuais
A.5.32	Direitos de propriedade intelectual

A.5.35	Análise crítica independente da segurança da informação
A.5.36	Compliance com políticas, regras e normas para segurança da informação
A.6.04	Processo disciplinar
A.8.08	Gestão de vulnerabilidades técnicas

Coordenadores ou Gerentes

A.5.33	Proteção de registros
A.6.07	Trabalho remoto
A.7.07	Mesa limpa e tela limpa
A.7.08	Localização e proteção de equipamentos
A.8.01	Dispositivos endpoint do usuário
A.8.03	Restrição de acesso à informação
A.8.10	Exclusão de informações

Direção

A.5.01	Políticas de segurança da informação
A.5.03	Segregação de funções
A.5.04	Responsabilidades da direção

Diretoria Técnica

A.5.23	Segurança da informação para uso de serviços em nuvem
A.7.01	Perímetros de segurança física
A.7.04	Monitoramento de segurança física
A.7.05	Proteção contra ameaças físicas e ambientais
A.8.14	Redundância dos recursos de tratamento de informações

DPO

A.5.05	Contato com autoridades
A.5.34	Privacidade e proteção de DP

Emissores de comunicações (conforme quadro no PG-03)

A.5.14	Transferência de informações
---------------	------------------------------

Gerente de Implantação e manutenção

A.7.13	Manutenção de equipamentos
---------------	----------------------------

Gerente de NOC/Suporte

A.5.15	Controle de acesso
A.5.18	Direitos de acesso
A.5.22	Monitoramento, análise crítica e gestão de mudanças dos serviços de fornecedores
A.5.37	Documentação dos procedimentos de operação
A.7.02	Entrada física
A.8.02	Direitos de acessos privilegiados
A.8.06	Gestão de capacidade
A.8.26	Requisitos de segurança da aplicação

A.8.32 Gestão de mudanças

Recursos Humanos

A.6.01	Seleção
A.6.02	Termos e condições de contratação
A.6.03	Conscientização, educação e treinamento em segurança da informação
A.6.05	Responsabilidades após encerramento ou mudança da contratação
A.6.06	Acordos de confidencialidade ou não divulgação

SOC

A.5.06	Contato com grupos de interesse especial
A.5.07	Inteligência de ameaças
A.5.24	Planejamento e preparação da gestão de incidentes da segurança da informação
A.5.25	Avaliação e decisão sobre eventos da segurança da informação
A.5.26	Resposta a incidentes de segurança da informação
A.5.27	Aprendizado com incidentes de segurança da informação
A.5.28	Coleta de evidências
A.6.08	Relato de eventos de segurança da informação
A.8.07	Proteção contra Malware
A.8.15	Log
A.8.16	Atividade de monitoramento

THENIO GUSTAVO
MESQUITA

SOARES:02619258499

Digitally signed by THENIO
GUSTAVO MESQUITA
SOARES:02619258499
Date: 2026.04.08 08:22:20
-03'00'